

ラボ5.1: Linux システムのベースライン設定と強化

1. はじめに

1.1. 必要なリソース

- ControlThings プラットフォーム仮想マシン
- インターネット接続 (推奨)

1.2. 概要

このラボでは、Linuxシステムのシステムベースライン設定とシステム強化のプロセスについて説明します。そのために、ControlThings Platform VMで以下の手順を実行します

1.3. 目標

- 以下のシステムベースラインを収集する
 - ユーザーアカウント
 - インストール済みソフトウェア
 - システム構成
 - ネットワーク設定
- 以下のシステム強化を実行する
 - 弱いセキュリティ設定を特定する
 - ホストベースのファイアウォールを構成する

2. システムベースライン

ベースライン設定と強化のためのコマンドラインツールに焦点を当てます。これらは簡単にスクリプト化できるためです。この作業には、Debianの次期バージョン（Debian Testing）をベースにしたControlThings Platform VMを使用します。そのため、これらのスキルは、Debian、Ubuntu、そしてUbuntuをベースにしたあらゆるものの現在および将来のバージョンすべてに非常に適用可能です。これらのアクションのほぼすべては、他の主要な商用LinuxディストリビューションであるRed HatとSuseでも同じです。実際、これらのコマンドは、多くの新しいコマンドがリリースされ、古いコマンドに取って代わった2015年以降の、ほぼすべての最新のLinuxディストリビューションで動作するはずです

コマンドラインターミナルを開く

2.1. ユーザーアカウント

まず最初に、システム上に作成されたすべてのユーザーアカウントを特定します。これを行う最も普遍的な方法は、`/etc/passwd` ファイルを確認することです

```
cat /etc/passwd
```

✓ 成功

注：出力は異なる場合があります。

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
_apt:x:104:65534:/:/nonexistent:/bin/false
rtkit:x:105:110:RealtimeKit,,,:/proc:/bin/false
dnsmasq:x:106:65534:dnsmasq,,,:/var/lib/misc:/bin/false
messagebus:x:107:111:/:/var/run/dbus:/bin/false
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false
geoclue:x:109:115:/:/var/lib/geoclue:/bin/false
pulse:x:110:116:PulseAudio daemon,,,:/var/run/pulse:/bin/false
speech-dispatcher:x:111:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false
avahi:x:112:119:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
colord:x:113:120:colord colour management daemon,,,:/var/lib/colord:/bin/false
saned:x:114:121:/:/var/lib/saned:/bin/false
hplip:x:115:7:HPLIP system user,,,:/var/run/hplip:/bin/false
Debian-gdm:x:116:122:Gnome Display Manager:/var/lib/gdm3:/bin/false
control:x:1000:1000:Control Things User,,,:/home/control:/bin/zsh
Debian-exim:x:117:126:/:/var/spool/exim4:/bin/false
postgres:x:118:128:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
snort:x:119:129:Snort IDS:/var/log/snort:/bin/false
mysql:x:120:130:MySQL Server,,,:/nonexistent:/bin/false
beef-xss:x:121:131:/:/var/lib/beef-xss:/bin/false
systemd-coredump:x:998:998:systemd Core Dumper:/:/sbin/nologin
tss:x:103:133:TPM2 software stack,,,:/var/lib/tpm:/bin/false
tcpdump:x:122:135:/:/nonexistent:/usr/sbin/nologin
uidd:x:123:136:/:/run/uidd:/usr/sbin/nologin
```

このファイルの形式は次のとおりです

ユーザー名: レガシーパスワード: ユーザーID: グループID: メモ: ホームディレクトリ: シェル

? あなたのユーザーはどのユーザー ID control を持っていますか?

制御ユーザーのユーザー ID は 1000 です。最近の Linux ディストリビューションのほとんどは、サービス アカウントに 1000 未満の ID を使用し、通常のユーザーには 1000 より大きい ID を使用します。

? 他にも 1000 番台のユーザー ID を持つアカウントはありますか?

そんなことはないはずです。しかし、`cat /etc/passwd | cut -f 3 -d ':' | sort -n` すべてのユーザーIDを抽出して並べ替えることで、何か見落としがないか確認することはできます。

また、いずれかのアカウントに実際のシェル実行可能ファイル（`/bin/sh`、`/bin/bash` など `/bin/zsh`）が設定されているかどうかを確認するための簡単なチェックを行うこともできます。

```
cat /etc/passwd | grep sh
```

✓ 成功

出力は、お使いのVMのバージョンによって若干異なる場合があります。

```
root:x:0:0:root:/root:/bin/bash
control:x:1000:1000:Control Things User,,,:/home/control:/bin/bash
postgres:x:118:128:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
```

`/home/` 正確性は劣りますが、よりシンプルな確認方法として、フォルダ内にサブフォルダがいくつあるかを確認する方法があります

```
ls /home
```

✓ 成功

```
control
```

ユーザーが有効なユーザーになるために、ここにフォルダーが存在する必要はないことに注意してください。

2.2. インストール済みソフトウェア

手動でインストールされたソフトウェアはどこにでもインストールできるため、これは少し難しいです。最適な2つの方法は、まずLinuxディストリビューションのパッケージマネージャーでインストールされているパッケージを確認し、次に手動でインストールされたパッケージの最も一般的な場所を確認することです

```
dpkg -l
```

RedHat および Suse の場合、リリースされた年に応じて `rpm -qa`、`yum list installed` または `dnf list installed`

✓ 成功

出力は、お使いのVMのバージョンによって若干異なる場合があります。

```
Desired=Unknown/Install/Remove/Purge/Hold
| Status=Not/Inst/Conf-files/Unpacked/halF-conf/Half-inst/trig-aWait/Trig-pend
|/ Err?=(none)/Reinst-required (Status,Err: uppercase=bad)
||/ Name                               Version                               Architecture Description
+++-----
=====
ii accountsservice                     0.6.55-2                             amd64          query and
manipulate user account information
ii acl                                 2.2.53-8                             amd64          access
control list - utilities
ii adduser                             3.118                                all            add and
remove users and groups
ii adwaita-icon-theme                 3.36.1-2                             all            default icon
theme of GNOME
ii afl                                 2.52b-5                              amd64          instrumentation-driven fuzzer for binary formats
```

... 出力は続きます ... (`SPACE` 次のページに移動するには `q` を使用し、終了するには `q` を使用します)

Linux に各パッケージの内容のチェックサムを実行させ、変更されていないかどうかを確認することもできます。これは `nmmap` のような単一のパッケージに対して実行できます。

```
sudo debsums nmap
```

? 制御ユーザーのパスワードを覚えていますか?

もの

✓ 成功

/usr/bin/nmap	OK
/usr/bin/nping	OK
/usr/share/doc/nmap/changelog.Debian.gz	OK
/usr/share/doc/nmap/changelog.gz	OK
/usr/share/doc/nmap/copyright	OK
/usr/share/lintian/overrides/nmap	OK
/usr/share/man/de/man1/nmap.1.gz	OK
/usr/share/man/es/man1/nmap.1.gz	OK
/usr/share/man/fr/man1/nmap.1.gz	OK
/usr/share/man/hr/man1/nmap.1.gz	OK
/usr/share/man/hu/man1/nmap.1.gz	OK
/usr/share/man/it/man1/nmap.1.gz	OK
/usr/share/man/ja/man1/nmap.1.gz	OK
/usr/share/man/man1/nmap.1.gz	OK
/usr/share/man/man1/nping.1.gz	OK
/usr/share/man/pl/man1/nmap.1.gz	OK
/usr/share/man/pt/man1/nmap.1.gz	OK
/usr/share/man/pt_BR/man1/nmap.1.gz	OK
/usr/share/man/ro/man1/nmap.1.gz	OK
/usr/share/man/ru/man1/nmap.1.gz	OK
/usr/share/man/sk/man1/nmap.1.gz	OK
/usr/share/man/zh/man1/nmap.1.gz	OK

1〜5分待っても構わない場合は、インストールされている**すべてのパッケージのすべてのファイル**のハッシュを検証し、問題がないと報告されたすべてのファイルを除外して、ハッシュと一致しないファイルのみを残すこともできます

```
sudo debsums | grep -v OK
```

RedHat および Suse の場合の同等のコマンドは です `rpm -Va`。

警告

このコマンドを実行する場合は、ターミナルウィンドウで新しいタブを開いて、コマンドの実行中もこのラボの作業を継続することを強くお勧めします

✓ 成功

ハッシュと一致しないファイルは見つからないはずです。

`/opt` 手動でインストールされたソフトウェアの場合は、多くの ICS ソフトウェアがインストールされているフォルダーとフォルダーを確認するのが最適です `/usr/local/share`。

```
ls /opt
```

✓ 成功

Teeth

これは、Maltego のオープンソース インテリジェンス アプリケーションと連携する攻撃ツールである **Maltego Teeth** 用です。

```
ls /usr/local/share
```

✓ 成功

出力は、お使いのVMのバージョンによって若干異なる場合があります。

aegis-console	ctspi	fonts	rfcat
ca-certificates	ctui	logic	sgml
cti2c	ctvelocio	man	texmf
ctmodbus	cyberchef-512x512.png	ModbusPal.jar	ToorChat
ctserial	cyberchef.htm	psimulator	virtuaplant
ctserial-old	doc	pybuspirate	xml

ここでは、Debian または Kali リポジトリに含まれておらず、手動でインストールする必要があった、授業で使用または言及したツールの一部を確認できます。

2.3. システム設定

Linuxディストリビューションは数多く存在し、各社が独自のLinuxパッケージリポジトリをホストできるため、重要な質問の1つは、「このマシンはどこからアップデートを取得するのか」ということです。制御ネットワーク内にいる場合、これは制御ネットワーク内のどこかにあるサーバーを指していると考えられます

これは Linux ディストリビューションごとに異なりますが、ここでは Ubuntu と Debian の方法を示します。

```
cat /etc/apt/sources.list
```

✓ 成功

```
cat: /etc/apt/sources.list: No such file or directory
```

ほとんどの Ubuntu および Debian ベースのディストリビューションでは、この `/etc/apt/sources.list` ファイルをリポジトリの主なリストとして使用していますが、ControlThings Platform では、Debian でもまだ移行していない最新の Debian 標準を使用しています。

```
ls /etc/apt/sources.list.d
```

✓ 成功

```
debian.sources  kali.sources  vsodium.sources
```

1つのコマンドを使って、これら3つのファイルの内容すべてを確認してみましょう

```
cat /etc/apt/sources.list.d/*
```

✓ 成功

```
Types: deb
URIs: https://deb.debian.org/debian/
Suites: sid bullseye
Components: main contrib non-free
Signed-By: /usr/share/keyrings/debian-archive-keyring.gpg

Types: deb
URIs: http://http.kali.org/kali
Suites: kali-rolling
Components: main non-free contrib
Signed-By: /usr/share/keyrings/kali-archive-keyring.gpg
Architectures: amd64

Types: deb
URIs: https://paulcarroty.gitlab.io/vscodium-deb-rpm-repo/debs/
Suites: vscodium
Components: main
Signed-By: /usr/share/keyrings/vscodium-archive-keyring.gpg
```

2.4. ネットワーク設定

警告

このセクションのすべての成功例は、それぞれ異なるネットワークを使用しているため、実際の出力とは若干異なります。出力構文は同じですが、正確な詳細は異なります

ベースラインとして、ネットワーク構成と現在の設定を収集することも重要です。Linuxには使用できるネットワークコマンドがいくつかありますが、そのほとんどは新しい `ip` コマンドに統合されています。

```
ip link
```

または `ip l` 略して。これにより、このマシン上のネットワークインターフェースとそのハードウェアアドレスが表示されます。

✓ 成功

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN mode DEFAULT group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP mode DEFAULT group default
    qlen 1000
    link/ether 08:00:27:38:18:cf brd ff:ff:ff:ff:ff:ff
```

正確な詳細は異なります。

```
ip -s link
```

これらのリンクの統計情報が表示 `-s` されるので、これらのインターフェースが使用しているトラフィック量を把握できます。

✓ 成功

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN mode DEFAULT group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    RX: bytes  packets  errors  dropped overrun mcast
      10910      129      0        0        0        0
    TX: bytes  packets  errors  dropped carrier collsns
      10910      129      0        0        0        0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP mode DEFAULT group default
    qlen 1000
    link/ether 08:00:27:38:18:cf brd ff:ff:ff:ff:ff:ff
    RX: bytes  packets  errors  dropped overrun mcast
      129603499  101616      0        0        0        0
    TX: bytes  packets  errors  dropped carrier collsns
      1810002    21015      0        0        0        0
```

正確な詳細は異なります。

ip address

または `ip a` 略して。これにより、現在インターフェースに割り当てられている IPv4 および IPv6 アドレスが表示されます。

✓ 成功

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:38:18:cf brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 78722sec preferred_lft 78722sec
    inet6 fe80::a00:27ff:fe38:18cf/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

正確な詳細は異なります。

ip neighbor

略し `ip n` で「」です。これは、マシンと同じネットワーク内にある、学習済みの他のシステムを表示します。これは、`arp` Windowsや従来のLinuxシステムのコマンドで表示される情報と同じです。マシンは仮想ネットワーク内にあるため、このリストにはおそらく1台のマシンしか表示されないでしょう。

✓ 成功

```
10.0.2.2 dev eth0 lladdr 52:54:00:12:35:02 STALE
```

正確な詳細は異なります。

💡 ヒント

これはラボの一部ではありません。しかし、VMをネットワークにブリッジ接続すると、さらに多くのマシンが表示されます。特に、ご自身のブリッジネットワークに `nmap -sn <network>` 置き換えてネットワークのpingスキャンを実行すると、さらに多くのマシンが表示されます。 `<network>` 例えば、私のマシンが現在接続されているネットワークは

```
10.0.2.0/24
```

ip route

または `ip r` 略して。これはあなたのマシンのルーティングテーブルを表示します。で始まる行は、`default` 宛先IPがローカルネットワーク内になく、カスタムルートが指定されていない場合に、あなたのマシンがすべてのトラフィックを送信するルーターになります。

✓ 成功

```
default via 10.0.2.2 dev eth0 proto dhcp metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
```

正確な詳細は異なります。

ss

これは**Socket Statistics**の略です。以前のコマンドに代わる新しいコマンドです `netstat`。デフォルトでは、マシンに現在確立されているすべてのネットワーク接続が表示されます。これらのほとんどには、**Local Address 列**と**Peer Address ***列にが表示され、場合によってはファイルパスが表示されます。これらはローカル Unix ソケット、つまり Linux と Unix で使用されるファイルベースの**API**です。講義で説明しました。

✓ 成功

これは、表示される多数の行のうち、大幅に短縮されたサンプルです。

Netid	State	Recv-Q	Send-Q	Local Address:Port
Peer Address:Port	Process			
u_str	ESTAB	0	0	* 17496
* 17497				
u_str	ESTAB	0	0	/run/user/1000/bus 23560
* 23559				
u_str	ESTAB	0	0	/run/systemd/journal/stdout 22877
* 22876				
icmp6	UNCONN	0	0	*:58
:				
udp	ESTAB	0	0	10.0.2.15%eth0:68
10.0.2.2:67				

正確な詳細は異なります。

ss -ltu

確立済みの接続ではなく、待機中のサービスを表示するためのコマンドオプションをいくつか追加できます。は、待機中のCPポートとDPポート `-ltu` を表します。 `L T U`

✓ 成功

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer
Address:Port	Process				
udp	UNCONN	0	0	0.0.0.0:mdns	
0.0.0.0:*					
udp	UNCONN	0	0	0.0.0.0:631	
0.0.0.0:*					
udp	UNCONN	0	0	0.0.0.0:40836	
0.0.0.0:*					
udp	UNCONN	0	0	:::mdns	
:::*					
udp	UNCONN	0	0	:::38940	
:::*					
tcp	LISTEN	0	80	127.0.0.1:mysql	
0.0.0.0:*					
tcp	LISTEN	0	5	127.0.0.1:ipp	
0.0.0.0:*					
tcp	LISTEN	0	511	*:http	
:					
tcp	LISTEN	0	5	:::1:ipp	
:::*					

正確な詳細は異なります。

```
sudo ss -ltunp
```

を追加すると、`-n` 数値 `N` ポート番号と開いているポートの背後にあるプロセス `-p` が表示されます `P`。を追加しない場合は `sudo`、ポートの背後にあるプロセスの一部、つまりユーザーが開始したサービス（先ほど使用した `modbuspal` など）のみが表示されます。

✓ 成功

Netid	State	Recv-Q	Send-Q	Local Address:Port
Peer Address:Port	Process			
udp	UNCONN	0	0	0.0.0.0:5353
0.0.0.0:*	users:(("avahi-daemon",pid=467,fd=12))			
udp	UNCONN	0	0	0.0.0.0:631
0.0.0.0:*	users:(("cups-browsed",pid=498,fd=7))			
udp	UNCONN	0	0	0.0.0.0:40836
0.0.0.0:*	users:(("avahi-daemon",pid=467,fd=14))			
udp	UNCONN	0	0	:::5353
:::*	users:(("avahi-daemon",pid=467,fd=13))			
udp	UNCONN	0	0	:::38940
:::*	users:(("avahi-daemon",pid=467,fd=15))			
tcp	LISTEN	0	80	127.0.0.1:3306
0.0.0.0:*	users:(("mysqld",pid=876,fd=19))			
tcp	LISTEN	0	5	127.0.0.1:631
0.0.0.0:*	users:(("cupsd",pid=470,fd=7))			
tcp	LISTEN	0	511	*:80
::*	users:(("apache2",pid=561,fd=4),("apache2",pid=560,fd=4),("apache2",pid=559,fd=4),("apache2",pid=558,fd=4),("apache2",pid=557,fd=4),("apache2",pid=556,fd=4),("apache2",pid=547,fd=4))			
tcp	LISTEN	0	5	:::1:631
:::*	users:(("cupsd",pid=470,fd=6))			

正確な詳細は異なります。

3. システム強化

3.1. Lynis

堅牢化に最適なツールの一つがLynisです。時間の制約があるため、ここでは表面的な部分しか紹介できませんが、Lynisの機能についてご理解いただければ幸いです。このツールは仮想マシンにローカルにインストールされていますが、ほとんどのLinuxおよびUnixディストリビューションでは、インストールやシステム変更なしでUSBドライブやネットワーク共有から実行できます。

```
sudo lynis audit system
```

警告: このツールの出力は非常に長くなります。

✓ 成功

注意: 出力は若干異なる場合があります。

```
[ Lynis 3.0.6 ]
```

```
#####  
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are  
welcome to redistribute it under the terms of the GNU General Public License.  
See the LICENSE file for details about using this software.
```

```
2007-2021, CISOfy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)
```

```
#####
```

```
[+] Initializing program
```

```
-----
```

```
=====
```

... 出力の大部分が削除されました...

```
=====
```

```
-[ Lynis 3.0.6 Results ]-
```

```
Warnings (2):
```

```
-----
```

```
! grpck binary found errors in one or more group files [AUTH-9216]  
  https://cisofy.com/lynis/controls/AUTH-9216/
```

```
! iptables module(s) loaded, but no rules active [FIRE-4512]  
  https://cisofy.com/lynis/controls/FIRE-4512/
```

```
Suggestions (47):
```

```
-----
```

```
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]  
  https://cisofy.com/lynis/controls/DEB-0280/
```

```
* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]  
  https://cisofy.com/lynis/controls/DEB-0810/
```

...出力は継続します...

上記の成功インジケータでは、出力の最後のセクションの最初の部分を示しています。これはLynisレポートです。上記の**警告が2件、提案が47件**あることに注目してください。

最初の警告**[AUTH-9216]**は、Linux グループファイルのエラーに関するものです。提供されているURLにアクセスすると、**grpck** グループファイルで見つかった特定の問題を検出するためのツールを実行するように提案されます。

```
sudo grpck
```

✓ 成功

```
[sudo] password for control:
```

```
'control' is a member of the 'adm' group in /etc/group but not in /etc/gshadow
```

```
'control' is a member of the 'dialout' group in /etc/group but not in /etc/gshadow
```

```
'control' is a member of the 'users' group in /etc/group but not in /etc/gshadow
```

```
'control' is a member of the 'wireshark' group in /etc/group but not in /etc/gshadow
```

つまり、ユーザーは **control** メイン **/etc/group** ファイル内のグループには追加されているものの、より安全な **/etc/gshadow** ファイルには追加されていないようです。ここで懸念されるのは、安全性の低いファイルが攻撃者によって何らかの形で編集されている可能性があることです。コース作成者が意図的にこれらの変更を加えたという事実を考慮すると、ここでは問題はありません。必要であれば、で編集し **/etc/gshadow**、上記の4つのグループに **sudo gedit /etc/gshadow** ユーザーを追加することで、手動で修正できます。 **control**

2 番目の警告**[FIRE-4512]**については、次に説明します。

3.2. iptables

iptablesを使い始める前に、まずControlThings仮想マシンで開いているサービスを確認する必要があります。これを行うには2つの方法があります。1つは、またはコマンドを使ってオペレーティングシステムに開いているサービスを尋ねる **ss** 方法 **netstat**、もう1つはローカルホストの基本的なNmapスキャンを実行する方法です

```
sudo nmap localhost --reason
```

✓ 成功

```
Starting Nmap 7.92 ( https://nmap.org ) at 2022-01-23 17:19 MDT
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 997 closed ports
Reason: 997 resets
PORT      STATE SERVICE REASON
80/tcp    open  http   syn-ack ttl 64
631/tcp   open  ipp    syn-ack ttl 64
3306/tcp  open  mysql  syn-ack ttl 64

Nmap done: 1 IP address (1 host up) scanned in 0.04 seconds
```

Nmapのオプション `--reason` では、各ポートが開いているか閉じているかを判断する理由が表示されます。ここでは3つのポートが開いていることがわかります。仮想マシンによって開いているポートの数は異なる場合があります。

以前実行したコマンドと比べてどうですか `sudo ss -ltunp` ? 覚えていない場合は、そのコマンドをもう一度実行してみてください。

3.2.1. ファイアウォールルールセット

次に、ファイアウォールルールセットを設定して、`iptables` どのネットワークトラフィックを許可し、何を拒否するかを選択します

`gedit iptables` スクリプトを作成するには、次のコマンドを使用します。

```
gedit iptables.sh
```

✓ 成功

GEditグラフィカルプログラムで新しい空のファイルが開きます。

GEEditウィンドウに次の行を入力してスクリプトを作成します

```
iptables -F
iptables -A INPUT -p tcp --dport 22 -j DROP
iptables -A INPUT -p tcp --dport smtp -j DROP
iptables -A INPUT -p tcp --dport 80 -j ACCEPT -s 127.0.0.1
iptables -A INPUT -p tcp --dport https -j ACCEPT -s 127.0.0.1
iptables -A INPUT -p tcp --dport http -j REJECT
iptables -A INPUT -p tcp --dport 443 -j REJECT
```

注

ポート番号を使用するか、登録済みのサービス名を使用するかは問題ではありません。この点を理解しやすくするために、名前と番号を交互に使用してもらっています

ファイルを保存してgeditウィンドウを閉じます

次に、ターミナルに戻り、ファイアウォールを起動するスクリプトを実行します。

```
sudo bash iptables.sh
```

✓ 成功

何も報告がないのは良い知らせです。もし何か出力が返ってきたら、それはたいていエラーです。

実行されていないサービス/ポートに対してファイアウォールルールを作成したことに注意してください。

最初の2つのルールはDROPアクションを使用しており、リクエストへの応答は発生しません。最後の2つのルールはアクションを使用しており、リクエスト元にこれらのポートが到達不能であることを通知するICMPメッセージが送信されます。をオーバー **REJECT** する必要がある理由はいくつかありますが、それはこのクラスの範囲外です。 **DROP REJECT**

ACCEPT 同じポートのDROPルールの前に、2つのルールを入力する必要があります。ポート **80** とポートのルールのうち **443**、最初に一致したルールが指定されたアクションを実行します。つまり、ポートとポートの **localhost** どちらかのルールが最初に一致するため、それらのポートへのトラフィックは許可されます。ただし、別のコンピュータからそれらのポートへのトラフィックは、ルールに到達するまで一致しません **REJECT**。

3.2.2. ファイアウォールテスト

ファイアウォールが正しく動作していることを確認するために、いくつかのテストを実行してみましょう

次に、次のように入力します。

```
sudo nmap localhost --reason
```

✓ 成功

```
Starting Nmap 7.92 ( https://nmap.org ) at 2022-01-23 17:19 MDT
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 995 closed ports
Reason: 995 resets
PORT      STATE      SERVICE    REASON
22/tcp    filtered  ssh        no-response
25/tcp    filtered  smtp       no-response
80/tcp    open       http       syn-ack ttl 64
631/tcp   open       ipp        syn-ack ttl 64
3306/tcp   open       mysql      syn-ack ttl 64

Nmap done: 1 IP address (1 host up) scanned in 1.25 seconds
```

ここでは、最初に実行したのと同じNmapコマンドを実行しています。インジケーターに示されているように、TCPポートとへのアクセスが切断されていることがわかります 22。Nmap 25 はローカルホストのIPアドレス（）を使用してスキャンを実行しており、これはiptablesルールで許可されているため、ポートとには `no-response` まだアクセスできます。仮想マシンによって開いているポートの数は異なる場合がありますのでご注意ください 80 443 127.0.0.1

nmapコマンドを少し変更するだけで、nmapにIPアドレスを別の送信元IPアドレスに偽装するよう指示できます。次のように入力します。

```
sudo nmap localhost --reason -S 127.1.1.1 -e lo
```

✓ 成功

```
WARNING: If -S is being used to fake your source address, you may also have to use -e <interface> and -
Pn . If you are using it to specify your real source address, you can ignore this warning.
Starting Nmap 7.92 ( https://nmap.org ) at 2022-01-23 17:19 MDT
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.000011s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 994 closed ports
Reason: 994 resets
PORT      STATE    SERVICE REASON
22/tcp    filtered ssh      no-response
25/tcp    filtered smtp     no-response
80/tcp    filtered http     port-unreach ttl 64
443/tcp   filtered https    port-unreach ttl 64
631/tcp   open     ipp        syn-ack ttl 64
3306/tcp  open     mysql      syn-ack ttl 64

Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds
```

127.1.1.1 は技術的にはループバックアドレスですが (127.0.0.0 - 127.255.255.255 すべてがループバックアドレスです)、iptablesルールでは明示的に のみを許可しています 127.0.0.1。そのため、iptablesがポート と へのアクセスをICMP応答で拒否していることがわかります 80。 443 また Port Unreachable、ポート (HTTPS) については、ルールを作成したため、そのポートでリッスンしているサービスがないにもかかわらず、フィルタリングされた応答が返されていることに 443 も注意してください。

3.2.3. ファイアウォールを無効にする

-L またはオプションを使用して、iptables 内のすべてのルールを一覧表示できます。また、同じコマンドでルールを入力する際に を に --list 変更することで、一度に 1 つのルールを削除することもできます。最後に、すべてのルールを削除したい場合は、 を 使用して、指定したチェーンのすべてのルールを削除します。チェーンのみを使用しているため、必要なフラッシュルールは 1 つだけです。iptablesコマンドでルールが表示されない場合は、ファイアウォールは基本的にオフになっており、何も実行されていない状態です。 -A -D -F INPUT -L

sudo iptables -L

✓ 成功

```
Chain INPUT (policy ACCEPT)
target     prot opt source                destination
DROP      tcp  --  anywhere              anywhere            tcp dpt:ssh
DROP      tcp  --  anywhere              anywhere            tcp dpt:smtp
ACCEPT    tcp  --  localhost             anywhere            tcp dpt:http
ACCEPT    tcp  --  localhost             anywhere            tcp dpt:https
REJECT     tcp  --  anywhere              anywhere            tcp dpt:http reject-with icmp-port-
unreachable
REJECT     tcp  --  anywhere              anywhere            tcp dpt:https reject-with icmp-port-
unreachable

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
```

sudo iptables -F

✓ 成功

応答は不要です。

sudo iptables -L

✓ 成功

```
Chain INPUT (policy ACCEPT)
target     prot opt source                destination

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
```

4. ボーナスチャレンジ

他の参加者がラボを完了するのを待っている場合、またはこのラボで紹介された概念をさらに深く探求したい場合は、いくつかのアイデアを試してみてください。これらのチャレンジにはチュートリアルは提供されていませんが、行き詰まった場合は、コース作成者のJustinに取り組みを示せば、喜んでヒントを教えてください。justin [@controlthings.io](mailto:justin@controlthings.io)までメールでお問い合わせください

例

からの約47件の提案のいくつかを試してみましょう `lynis`。それぞれの提案で提供されているURLを必ず使用してください